

Advanced SQL Injection & Role-Based Access Control (RBAC) Labs:

LAB 01:

-CREATE GROUP ROLE

```
3 CREATE ROLE cashier_role;
4
5 --
6 CREATE USER Mike WITH PASSWORD 'm1ke';
7 CREATE USER Jon WITH PASSWORD 'j0n';
8
9 --
10
```

Data Output

Messages

Notifications

CREATE ROLE

Query returned successfully in 47 msec.

- CREATE USER ACCOUNTS

```
5  --
6  CREATE USER Mike WITH PASSWORD 'm1ke';
7  CREATE USER Jon WITH PASSWORD 'j0n';
8
9  --
10
```

Data Output Messages Notifications 

CREATE ROLE

Query returned successfully in 60 msec.

- ASSIGN USERS TO THE GROUP

```
9  --
10 GRANT cashier_role TO Mike;
11 GRANT cashier_role TO Jon;
```

Data Output Messages Notifications 

GRANT ROLE

Query returned successfully in 37 msec.

- ASSIGN PERMISSIONS ON TABLES

```
14 GRANT SELECT ON film TO cashier_role;  
15 GRANT SELECT ON staff TO cashier_role;  
16 GRANT SELECT, INSERT ON payment TO cashier_role;
```

Data Output Messages Notifications

GRANT

Query returned successfully in 39 msec.

WHOLE SCRIPT:

```
2  --  
3  CREATE ROLE cashier_role;  
4  
5  --  
6  CREATE USER Mike WITH PASSWORD 'm1ke';  
7  CREATE USER Jon WITH PASSWORD 'j0n';  
8  
9  --  
10 GRANT cashier_role TO Mike;  
11 GRANT cashier_role TO Jon;  
12  
13 --  
14 GRANT SELECT ON film TO cashier_role;  
15 GRANT SELECT ON staff TO cashier_role;  
16 GRANT SELECT, INSERT ON payment TO cashier_role;  
17
```

LAB 02:

- SET UP RLS

```
18  --
19  ALTER TABLE payment ENABLE ROW LEVEL SECURITY;
```

Data Output Messages Notifications

ALTER TABLE

Query returned successfully in 39 msec.

- CREATE THE POLICY

```
22  CREATE POLICY isolate_cashier_payments ON payment
23  FOR SELECT
24  TO cashier_role
25  USING(
26      staff_id = (SELECT staff_id FROM staff WHERE LOWER(username)= current_user)
27  );
```

Data Output Messages Notifications

CREATE POLICY

Query returned successfully in 57 msec.

- TEST POLICY

for Mike

```
30  SET ROLE Mike;
31
```

Data Output Messages Notifications

SET

Query returned successfully in 46 msec.

```
30 SET ROLE Mike;
31 SELECT * FROM payment;
```

	payment_id [PK] integer	customer_id smallint	staff_id smallint	rental_id integer	amount numeric (5,2)	payment_date timestamp without time zone
1	17504	341	1	1778	1.99	2007-02-16 17:23:14.996577
2	17505	341	1	1849	7.99	2007-02-16 22:41:45.996577
3	17508	341	1	3382	5.99	2007-02-21 12:33:49.996577
4	17510	342	1	2914	5.99	2007-02-20 02:11:44.996577
5	17511	342	1	3081	2.99	2007-02-20 13:57:39.996577
6	17513	343	1	1564	6.	

Showing rows: 1 to 1000 Page No: 1 of 8

✓ Successfully run. Total query runtime: 541 msec. 7292 rows affected. ✕

For Jon

```
33 SET ROLE Jon;
34 SELECT COUNT(*) FROM payment;
```

	count bigint
1	7304

-WHOLE SCRIPT:

```
18 --
19 ALTER TABLE payment ENABLE ROW LEVEL SECURITY;
20
21 --|
22 CREATE POLICY isolate_cashier_payments ON payment
23 FOR SELECT
24 TO cashier_role
25 USING(
26     staff_id = (SELECT staff_id FROM staff WHERE LOWER(username)= current_user)
27 );
28
29 --
30 SET ROLE Mike;
31 SELECT * FROM payment;
32
33 SET ROLE Jon;
34 SELECT COUNT(*) FROM payment;
```